



Технический Исследовательский Компендиум

Privileged Access Management, AI Security Governance & Emergency
Access Controls
2020–2026

Источников: 85+ технических документов

Базы данных: arXiv, IEEE, NIST, vendor docs (CyberArk, HashiCorp, Delinea)

Категорий: 14 основных разделов

Дата генерации: 2026-05-02



Table of Contents

- 1. Executive Summary**
- 2. Privileged Access Management (PAM) Process**
 - 2.1 Core PAM Architecture & Best Practices
 - 2.2 Zero Standing Privileges & Just-In-Time Access
- 3. Break-Glass Accounts & Emergency Access**
 - 3.1 Break-Glass Design Principles
 - 3.2 Industry Implementation Patterns
- 4. Out-of-Band Access Policy & Management**
- 5. Critical Incident Response Policy & NIST Framework**
 - 5.1 NIST SP 800-61 Lifecycle
 - 5.2 Administrative Escalation & Emergency Override
- 6. AI Security Agents & SecOps**
 - 6.1 Autonomous SOC Agents & Copilot Frameworks
 - 6.2 Agent Governance & Runtime Security
- 7. Shadow Admin, Backdoor & Service Account Access**
 - 7.1 Shadow Admin Detection (ACLIGHT, BloodHound)
 - 7.2 Service Account Attack Vectors & Lateral Movement
- 8. Split Knowledge & Emergency Key Recovery**
- 9. National AI Governance & Policy Frameworks**
 - 9.1 US National Policy Framework 2026
 - 9.2 National Security AI Governance
- 10. Corporate AI Ethics, Safety Policy & Content Filtering**
 - 10.1 LLM Guardrails & Content Filtering Architectures
 - 10.2 AI Safety Override & Kill Switch Standards
- 11. Secure Operations Framework & User Segmentation**
 - 11.1 Zero Trust Segmentation & Microsegmentation
 - 11.2 Identity-Based Segmentation Policies
- 12. Master Control Directive & System Policy**
- 13. Disaster Recovery Plan & DRP Appendix**
- 14. Complete Reference List**

1. Executive Summary

This compendium collects and categorizes 85+ technical sources from 2020–2026 covering privileged access management (PAM), break-glass emergency procedures, AI security agent governance, out-of-band access, shadow admin detection, national AI policy frameworks, and secure operations. Sources include vendor technical documentation (CyberArk, HashiCorp Vault, Delinea/Thycotic), NIST publications, academic papers from arXiv and IEEE, and government policy documents.

Category	Sources	Key Sources
PAM Process & JIT Access	12	CyberArk, Delinea, BeyondTrust
Break-Glass & Emergency Access	14	HashiCorp, Yale HIPAA, Bravura
Out-of-Band Access Policy	8	NSA, Cisco, HPE iLO
Incident Response & NIST	10	NIST SP 800-61r2, Compliance
AI Security Agents & SecOps	12	Microsoft Copilot, arXiv surveys
Shadow Admin & Backdoor Detection	8	CyberArk Labs, ACLight
Split Knowledge & Key Recovery	4	Commvault, Vitalik Buterin
National AI Governance	10	White House 2026, CSET, Brookings
AI Ethics & Content Filtering	10	AWS Bedrock, NVIDIA NeMo, OneShield
Secure Ops & Segmentation	7	CISA, Duo, Tigera, Zero Networks
Master Control & Safety Override	5	KILLSWITCH.md, AILCCP, Stanford
Disaster Recovery & DRP	5	Delinea Secret Server, Grid Dynamics

Temporal Distribution: 47 sources from 2024–2026 reflecting the rapid evolution of AI governance and agentic security. 18 sources from 2020–2023 provide foundational PAM and incident response frameworks. The **2026 US National Policy Framework for AI** represents the most significant recent policy development.

Key Terms Covered:

PAM Break-Glass JIT Access ZSP OOB Management NIST 800-61 AI Agents SecOps
 Shadow Admin ACLight Split Knowledge M-of-N AI Governance EU AI Act Kill Switch
 Microsegmentation Zero Trust LLM Guardrails DRP Resilient Secrets Policy-as-Code

PAM

Zero Standing Privileges

JIT Access

Vaulting

Session Management

2. Privileged Access Management (PAM) Process

Privileged Access Management encompasses the technologies, policies, and procedures for securing, monitoring, and governing elevated access to critical systems. This section covers core PAM architecture, just-in-time access models, and credential vaulting implementations from leading vendors.

2.1 Core PAM Architecture & Best Practices

Technical foundations of PAM systems including credential vaulting, session isolation, and rotation mechanisms.

Cloud Access Simplified, Secured, and Just a Request Away

Source: CyberArk | Date: November 2025

CyberArk's PAM architecture builds on vaulting, credential rotation, and session management, adding Zero Standing Privileges (ZSP) and Just-In-Time (JIT) access. Critical break-glass scenarios requiring immediate privileged access can be requested directly within the platform, eliminating approval hoops while maintaining audit trails...

<https://www.cyberark.com/resources/product-insights-blog/cloud-access-simplified-secured-and-just-a-request-away>

8 Privileged Access Management (PAM) Best Practices for Cloud Infrastructure

Source: Apono | Date: January 2025

The global PAM market is expected to grow from \$2.9 billion in 2023 to \$7.7 billion by 2028. Best practices include identifying all privileged accounts, securely storing credentials in encrypted vaults, applying least privilege, and using auditing to track who accessed what, when, and why...

<https://www.apono.io/blog/8-privileged-access-management-pam-best-practices-for-cloud-infrastructure/>

How to Design a PAM Break Glass Process

Source: Security-Architect.com | Date: January 2020

PAM systems themselves can become single points of failure if the credential vault is inaccessible. The security team must design break-glass processes ensuring administrators have backup access to credentials. Local accounts to CyberArk safes containing subsets of credentials provide fallback when AD is down...

<https://security-architect.com/how-to-balance-assurance-and-availability-in-pam-systems/>

Platform Security Best Practices — Delinea

Source: Delinea | Date: 2026

Provision two CloudAdmin-level emergency access accounts not assigned to individual human users. Enforce AAL3 MFA using FIDO2/YubiKeys. Integrate HSM for Master Encryption Key management. Avoid local accounts; use federated identity exclusively. Store MFA devices in secure physical vaults...

<https://docs.delinea.com/online-help/delinea-platform/getting-started/secure-tenant.htm>

Zero Trust Solutions — BeyondTrust

Source: BeyondTrust | Date: March 2026

BeyondTrust provides visibility across the identity estate, applies least privilege everywhere, implements JIT access, enables segmentation/microsegmentation, and manages credentials for humans, machines, and agentic AI. Identity Security Insights reveals True Privilege by visualizing hidden connections between accounts, privileges, and configurations...

<https://www.beyondtrust.com/solutions/zero-trust>

2.2 Zero Standing Privileges & Just-In-Time Access

Modern PAM eliminates persistent admin rights by granting elevated access only when needed, for a limited duration, with full audit coverage.

Zero Trust Segmentation: A Guide For Security Leaders

Source: Cisco Duo | Date: January 2026

Six steps to implement zero trust segmentation: define assets and data sensitivity, map communication flows, enforce identity-based policies, implement microsegmentation, enable continuous monitoring, and optimize iteratively. Time-based access and just-in-time access reduce exposure if credentials are compromised...

<https://duo.com/learn/zero-trust-segmentation>

A Guide to Least Privilege Access: Zero Trust Security in Action

Source: Zero Networks | Date: October 2025

Only 2.6% of workload identity permissions are actually used, and 51% of workload identities are completely inactive. Admin and service accounts should be limited to approved actions with identity segmentation. Enforce just-in-time MFA for privileged access, keeping privileged ports closed by default...

<https://zeronetworks.com/blog/a-practical-guide-to-least-privilege-access-zero-trust-security-in-action>

Navigating the Break Glass Process in Cloud Operations

Source: Grid Dynamics | Date: January 2024

Modern PAM solutions like CyberArk and HashiCorp Vault handle credentials storage, release, rotation and logging. Dedicated instances should be used specifically for break-glass credentials management to minimize attack surface. Periodic drills are essential to keep emergency access methods working...

<https://www.griddynamics.com/blog/break-glass-process-cloud-operations>

Break-Glass

Emergency Override

Critical Unlock

Master Admin

Unlimited Admin

3. Break-Glass Accounts & Emergency Access

Break-glass accounts provide emergency access when standard authentication mechanisms fail. This section covers design principles, implementation patterns, and vendor-specific technical configurations for secure emergency access.

3.1 Break-Glass Design Principles

Foundational requirements for break-glass account creation, storage, monitoring, and lifecycle management.

Break Glass Procedure: Granting Emergency Access to Critical ePHI Systems

Source: Yale University HIPAA Security | Date: Ongoing

Break-glass is based upon pre-staged emergency user accounts managed to be available with reasonable administrative overhead. Username should be obvious and meaningful (e.g., breakglass01). Account permissions must be set to minimum necessary privilege. Auditing should be enabled to log details of account usage and work carried out...

<https://hipaa.yale.edu/security/break-glass-procedure-granting-emergency-access-critical-ephi-systems>

Break Glass Access in HashiCorp Boundary

Source: Hoop.dev | Date: September 2025

Break glass procedures with Boundary require: a predefined emergency user or role, short-lived credentials with strict TTL policies, logged and observable actions stored centrally, and immediate revocation after the incident. Emergency accounts should be disabled by default, activated only through documented auditable process...

<https://hoop.dev/blog/break-glass-access-in-hashicorp-boundary-designing-for-speed-and-security>

Building a Break Glass Solution with HashiCorp Boundary + Vault

Source: Maniak Academy / Medium | Date: January 2023

Best practices for managing Break Glass accounts: limit access to trusted individuals, establish clear procedures, monitor and audit usage, secure with strong unique credentials and MFA, test regularly, have incident response plan, and set expiration dates. Integration of Boundary and Vault uses Vault's authentication and authorization to control access...

<https://maniakacademy.medium.com/building-a-break-glass-solution-using-hashicorp-boundary-vault-307a5cfd56d9>

Break Glass Accounts: Best Practices for Emergency Access

Source: Encryptorium / Medium | Date: October 2024

Create at least two break-glass accounts for redundancy. Use cloud-only accounts unlinked to on-premises directories. Apply standard naming conventions to avoid attention. Generate complex passwords up to 256 characters. Exclude from regular conditional access policies. Store credentials in secure fireproof locations; consider splitting passwords into parts...

<https://encryptorium.medium.com/break-glass-accounts-best-practices-for-emergency-access-in-privileged-account-management-a098560a2097>

Break Glass Explained: Why You Need It for Privileged Accounts

Source: StrongDM | Date: October 2025

A break-glass process features well-defined steps: determine who gets access, create pre-staged accounts with global admin rights exempt from normal controls, assign an emergency account manager. Typical procedure: user requests access, account manager verifies identity, requester gains access, procedure is monitored for auditing, account is disabled afterward...

<https://www.strongdm.com/blog/break-glass>

3.2 Industry Implementation Patterns

Vendor-specific break-glass implementations from CyberArk, Delinea/Thycotic, and HashiCorp Vault.

Break-glass access best practices — CyberArk

Source: CyberArk Documentation | Date: March 2026

Break-glass access allows designated users to bypass normal access controls during emergencies. CyberArk recommends: identify outage scenarios, grant access only to highly trusted operators, monitor and audit all activities. Security in layers: SCA provides ZSP; if unavailable, use break-glass credential managed in Privilege Cloud; if PAM is unavailable, use offline access via CyberArk mobile app...

<https://docs.cyberark.com/sca/latest/en/content/dpaforcloud/breakglass.htm>

Break glass privileged accounts for disaster recovery — Delinea

Source: Delinea | Date: March 2024

Delinea Secret Server supports break-glass via Unlimited Administrator mode where an administrator can access all secrets without explicit permission. RBAC can require two people to agree before activation. Automatic email alerts are sent whenever Unlimited Admin mode is accessed. Secret Server uses clustered environments with automatic failover..

<https://delinea.com/blog/break-glass-accounts>

Break Glass Scenarios — Delinea Secret Server

Source: Delinea Technical Docs | Date: 2026

Secret Server Break Glass options include: Export Secrets (offline encrypted CSV/XML), Resilient Secrets (local accounts with RBAC and audit logging), Mobile App Offline Caching (secrets cached for offline use), and PCS/Server Suite Agent Offline Operation (policy caching with machine-specific MFA for secure offline authentication)...

<https://docs.delinea.com/online-help/secret-server/backup-and-disaster-recovery/break-glass/index.htm>

Restrict API and storage access during incident response — HashiCorp Vault

Source: HashiCorp | Date: November 2021

Vault provides two critical break-glass features: Seal — an operator with sufficient privileges can seal Vault at any time, discarding in-memory keys and blocking all requests except status/unsealing; API Lock (v1.9.0+) — namespace-level API lockout preventing Vault from responding to all but status and unlocking requests without full seal...

<https://developer.hashicorp.com/vault/tutorials/operations/emergency-break-glass-features>

Lock resources — HCP Vault Secrets

Source: HashiCorp | Date: February 2024

HCP Vault Secrets allows administrators to lock resources as a break-glass procedure. When projects are locked, users cannot create apps, add secrets, view/edit secret values, or create integrations. The audit log captures all lock and unlock events. Users with admin role can lock across all apps within projects they administer..

<https://github.com/hashicorp/web-unified-docs/blob/main/content/hcp-docs//content/docs/vault-secrets/lock.md>
x

An Identity Security Playbook for Ransomware — Delinea

Source: Delinea | Date: November 2025

During ransomware recovery, Delinea Secret Server becomes a central control point: rotate compromised credentials, suspend check-outs, terminate active privileged sessions, bulk reset passwords. DON'T grant domain-wide break-glass or blanket admin during recovery. Time-box emergency elevation, require approvals, and record all sessions...

<https://delinea.com/blog/identity-security-playbook-for-ransomware>

OOB

Console Server

BMC

iLO

IPMI

Network Isolation

4. Out-of-Band Access Policy & Management

Out-of-band (OOB) management provides dedicated, isolated network paths for remote device administration independent of production network availability. This section covers NSA guidelines, Cisco best practices, and hardware implementations.

Performing Out-of-Band Network Management

Source: NSA / US Defense | Date: September 2020

NSA recommends implementing encryption on all OOB traffic using VPNs, hardening network management devices, restricting management access to dedicated hosts, implementing MFA, using only serial/console connections for critical devices, and establishing configuration management procedures. Use SNMPv3 with encryption; avoid SNMPv1/v2. Maintain ACLs permitting only needed services...

https://media.defense.gov/2020/Sep/17/2002499616/-1/-1/0/PERFORMING_OUT_OF_BAND_NETWORK_MANAGEMENT20200911.PDF

Solutions — Out of Band Best Practices (Cisco)

Source: Cisco | Date: November 2025

A typical OOB network is a purpose-built management infrastructure for secure, reliable access to mission-critical devices. Diverse connectivity: each management switch connects to different management routers. Physical separation of cabling. Console servers with redundant network connections. Dual power supplies on all devices. SD-WAN edge devices with LTE/5G as tertiary access...

<https://www.cisco.com/c/en/us/solutions/collateral/service-provider/out-of-band-best-practices-wp.html>

What is out of band management? A Quick Guide

Source: Soraxus | Date: January 2026

OOBM operates on a completely separate isolated network, providing a reliable backdoor to hardware even when the primary network is toast. Best practices: strict network isolation with dedicated hardware or VLANs, enforce MFA and RBAC, maintain comprehensive auditing and logging to centralized systems, and consider the OOBM network as the most privileged part of infrastructure...

<https://soraxus.com/blog/informational/what-is-out-of-band-management>

Out of Band Management | HPE Glossary

Source: HPE | Date: July 2025

HPE provides enterprise-grade OOBM centered around Integrated Lights-Out (iLO) technology. iLO enables remote server access even when the server is switched off or OS is unresponsive. Supports BIOS configuration, OS installation, firmware upgrades, and power cycling without physical contact. HPE OneView integrates OOBM with infrastructure management technology...

<https://www.hpe.com/us/en/what-is/out-of-band-management.html>

Essential Guide to Out-of-Band Management

Source: Advantech | Date: August 2024

Initial OOB setup requires sorting console access, setting IP addresses, and ensuring only authorized personnel can get in. Strong authentication, encrypted management traffic, and staying on top of software updates are essential. Console access allows admins to securely link up with the console server from afar, managing connected gadgets as if physically present...

<https://www.advantech.com/en-us/resources/industry-focus/out-of-band-management-guide>

NIST 800-61

IR Lifecycle

Containment

Escalation

Forensics

5. Critical Incident Response Policy & NIST Framework

Incident response policies define structured approaches to detecting, analyzing, containing, and recovering from security incidents. This section covers the NIST SP 800-61 framework, administrative escalation protocols, and emergency override procedures.

5.1 NIST SP 800-61 Lifecycle

The canonical four-phase incident handling guide from NIST, widely adopted across federal and private sectors.

NIST SP 800-61r2: Computer Security Incident Handling Guide

Source: NIST | Date: 2012 (rev. ongoing)

Defines four primary phases: Preparation (policies, roles, tools, training), Detection and Analysis (signals, triage, scope), Containment/Eradication/Recovery (isolate assets, rotate credentials, remove malicious components, verify integrity), and Post-Incident Activity (timeline, lessons learned, playbook updates). Each incident handler should have at least two computing devices...

<https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-61r2.pdf>

NIST SP 800-61 Guide — Compliance

Source: Compliance | Date: October 2025

NIST SP 800-61 provides a structured approach to preparing for, detecting, analyzing, and responding to security incidents. Core objectives: improve detection and response times, ensure coordination between technical and management teams, standardize reporting and evidence gathering, and decrease impact to restore normal operations...

<https://www.compliance.com/resources/nist-sp-800-61-guide>

Computer Security Incident Handling Guide — ScienceDirect

Source: ScienceDirect / NIST | Date: Ongoing

The incident response process includes establishing and training an incident response team, acquiring necessary tools, implementing controls based on risk assessments, detecting security breaches, containing incidents, eradicating malware, recovering systems, and issuing post-incident reports detailing cause, cost, and preventive steps...

<https://www.sciencedirect.com/topics/computer-science/computer-security-incident-handling-guide>

NIST SP 800-61 Incident Handling Checklist

Source: GitHub / Ethical Hacking Reference | Date: July 2024

Containment isolates affected systems to prevent spread. Eradication removes malicious software, closes exploited vulnerabilities, and identifies compromised accounts. Recovery restores data from backups and validates integrity before resuming operations. Post-incident reviews evaluate effectiveness and update policies accordingly...

https://github.com/tomwechsler/Ethical_Hacking_and_Penetration_Testing/blob/main/Documentation/NIST_Computer_Security_Incident_Handling_Guide.md

5.2 Administrative Escalation & Emergency Override

Procedures for escalating incident severity and executing emergency overrides when standard controls impede critical response.

NIST SP 800-61 for Third-Party Risk

Source: Mitratach | Date: November 2021

Containment strategies may involve suspending compromised accounts, blocking traffic, isolating systems, or redirecting attackers to sandbox environments. Third-party risk monitoring solutions assist with evidence collection, legal admissibility, and identifying attack hosts through IP validation and communication monitoring...

<https://mitratach.com/resource-hub/blog/nist-sp-800-61/>

Commvault Data Encryption and Key Management Guide

Source: Commvault / Bacula Systems | Date: July 2025

Emergency Key Recovery Protocols include: multi-person authentication preventing unauthorized access via split-knowledge procedures; administrative override capabilities for key access during disaster recovery; secure key reconstruction from distributed components; and comprehensive emergency documentation requirements. M-of-N key sharing requires multiple authorized personnel to reconstruct encryption keys...

<https://www.baculasystems.com/blog/commvault-data-encryption/>

Enhance Emergency Response with PAM Break-Glass Access

Source: Bravura Security | Date: September 2024

Bravura Privilege's break-glass feature ensures that during any service interruption, the response team has immediate access. Best practices include applying the four-eyes principle and parceling emergency passwords across multiple locations. Audit trails are crucial: SolarWinds (2020) showed how robust audit trails are essential for effective response and impact assessment...

<https://www.bravurasecurity.com/blog/emergency-break-glass>

AI Agents

SOC

LLM

Autonomous Response

Copilot

XDR

6. AI Security Agents & SecOps

AI-augmented Security Operations Centers use large language models and autonomous agents for alert triage, incident response, threat intelligence, and guided remediation. This section surveys deployed systems, governance frameworks, and runtime security controls.

6.1 Autonomous SOC Agents & Copilot Frameworks

Technical implementations of AI agents in production SOC environments, including Microsoft Copilot for Security and Palo Alto XSIAM.

AI-Driven Guided Response for Security Operation Centers with Microsoft Copilot

Authors: ['Caparas et al.'] | Date: 2024 | arXiv:2407.09017

Copilot Guided Response (CGR) is the first industry-scale guided response framework openly discussed by a cybersecurity company. CGR enhances SOC operations by guiding analysts through investigation, triaging, and remediation. Deployed globally within Microsoft Defender XDR, generating millions of recommendations weekly with 89% positive user feedback...

<https://arxiv.org/html/2407.09017v2>

AI-Augmented SOC: A Survey of LLMs and Agents for Security Automation

Authors: ['Multiple'] | Date: November 2025 | MDPI AI 5(4):95

Comprehensive survey of LLM and agent integration in SOCs. Five-level capability-maturity framework from Level 0 (Manual) to Level 4 (Fully Autonomous). AI agents reduce MTTD/MTTR by up to 6x compared to human intervention. Multi-agent systems like Audit-LLM show 40% reduction in false positives for insider threat detection. LogParser-LLM achieves 0.96 parsing accuracy...

<https://www.mdpi.com/2624-800X/5/4/95>

AI Agents for Threat Triage, Response, and Orchestration

Authors: ['Anitha Mareedu'] | Date: 2025 | IJERET 6(2):63-70

Autonomous remediation agents like SentinelOne Purple AI assess incident context and execute containment without analyst oversight. Google's Sec-PaLM powers investigative agents for evidence correlation and alert resolution. Palo Alto Cortex XSIAM fuses endpoint, network, and identity telemetry into a centralized data fabric, applying ML and behavioral analytics for automated detection and response...

<https://ijeret.org/index.php/ijeret/article/download/170/157>

Microsoft unveils Security Copilot agents and new protections for AI

Source: Microsoft Security Blog | Date: March 2025

Microsoft processes 84 trillion signals daily, including 7,000 password attacks per second. Six new Security Copilot agents: Phishing Triage Agent in Defender, Alert Triage Agents in Purview, Conditional Access Optimization Agent in Entra, Vulnerability Remediation Agent in Intune, and Threat Intelligence Briefing Agent. All built on Zero Trust framework...

<https://www.microsoft.com/en-us/security/blog/2025/03/24/microsoft-unveils-microsoft-security-copilot-agents-and-new-protections-for-ai/>

Agentic AI will be a focus for security operations in 2025

Source: S&P Global Market Intelligence | Date: April 2025

Agentic functionality may introduce latency as agents perform assessment within workflows rather than humans taking it "out of band." Organizations need to keep people engaged with more intelligently automated processes, informing them with evolving insight such as regulatory changes impacting security implementation. Hyperautomation combines RPA, detection engineering, and AI...

<https://www.spglobal.com/market-intelligence/en/news-insights/research/ai-for-security-agentic-ai-will-be-a-focus-for-security-operations-in-2025>

6.2 Agent Governance & Runtime Security

Governance frameworks for autonomous AI agents including kill switches, policy-as-code, and runtime enforcement.

Governing Autonomous AI Agents with Policy-as-Code

Authors: ['Fourth Industrial Systems'] | Date: December 2025 | SSRN 5820262

Proposes a unified Policy-as-Code governance architecture operationalizing regulatory mandates (EU AI Act, NIST AI RME, ISO/IEC 42001) into runtime-enforceable rules using cloud-native security controls, telemetry fusion, and automated risk scoring. Simulated multi-agent workflows across healthcare, finance, cybersecurity, and logistics show improved transparency and reduced policy deviation...

https://papers.ssrn.com/sol3/papers.cfm?abstract_id=5820262

Introducing the Agent Governance Toolkit — Open-Source Runtime Security

Source: Microsoft Open Source | Date: April 2026

The first toolkit addressing all 10 OWASP agentic AI risks with deterministic, sub-millisecond policy enforcement. Seven-package toolkit in Python, TypeScript, Rust, Go, .NET: Agent OS (stateless policy engine), Agent Mesh (cryptographic identity with DIDs), Agent Runtime (dynamic execution rings and kill switch), Agent SRE (SLOs, circuit breakers), Agent Compliance (regulatory mapping)...

<https://opensource.microsoft.com/blog/2026/04/02/introducing-the-agent-governance-toolkit-open-source-runtime-security-for-ai-agents/>

AI autonomy governance: A governance framework for agentic AI

Source: TM Forum / Inform | Date: March 2026

Structured governance framework for safe deployment and scaling of AI agents. Ten governance pillars: risk boundaries, human accountability, technical safeguards, user literacy, data governance, transparency, continuous monitoring, ethical design, regulatory compliance, and organizational culture. Agents require minimum necessary system access, sandbox environments, shutdown procedures, and verifiable digital identity...

<https://inform.tmforum.org/features-and-opinion/ai-autonomy-governance-a-governance-framework-for-agentic-ai-enabling-safe-accountable-and-scalable-autonomous-intelligence>

A Four-Layer Security Governance Framework for LLM-Based AI Agents

Authors: ['Yiang Gao', 'Shanshan Wu'] | Date: December 2025 | Journal of AI Practice 8:49-55

Covers the full Perception-Decision-Memory-Execution lifecycle to mitigate risks: multi-source perception failures, decision hallucination, memory poisoning, and malicious execution. Systematically maps each lifecycle phase to security requirements and controls for trustworthy development of AI agents...

<https://www.clausiuspress.com/article/17139.html>

The 2025 AI Agent Index: Documenting Technical and Safety Features

Authors: ['Multiple'] | Date: February 2026 | arXiv:2602.17753

Comprehensive annotation methodology for deployed agentic AI systems covering: company accountability (legal entity, governance docs, compliance claims), technical capabilities (model specs, observation/action space, memory architecture), autonomy and control (sandboxing, human approval, kill switch), and safety evaluation (red teaming, safety frameworks)...

<https://arxiv.org/html/2602.17753v1>

Shadow Admin

ACLight

BloodHound

ACL Abuse

Lateral Movement

Service Account

7. Shadow Admin, Backdoor & Service Account Access

Shadow admins possess administrative privileges through delegated ACLs rather than group membership, making them invisible to traditional admin checks. Service accounts and backdoors provide persistent access for attackers. This section covers detection methodologies and attack vectors.

7.1 Shadow Admin Detection (ACLight, BloodHound)

Technical approaches to discovering hidden privileged accounts in Active Directory through ACL analysis and graph-based detection.

Shadow Admins – The Stealthy Accounts That You Should Fear The Most

Source: CyberArk Labs | Date: June 2017

CyberArk Labs research indicates Shadow Admin accounts are prevalent in any organization using Active Directory. ACLight is a tool for discovering privileged accounts through advanced ACLs analysis. It can be run using any standard non-privileged account as it only reads ACLs. Output is a list of privileged accounts discovered from all connected domains...

<https://www.cyberark.com/resources/threat-research-blog/shadow-admins-the-stealthy-accounts-that-you-should-fear-the-most>

Shadow Admins in Active Directory: Hidden Privilege Paths Attackers Exploit

Source: Security Boulevard | Date: April 2026

Level 1 shadow admin has strong privileges over an existing admin account or domain admin group. Level 2 shadow admin holds privileges over a level 1 shadow, creating transitive chains. Detection requires continuously auditing all accounts and groups, examining not just direct group membership but the full transitive closure of permissions. Traditional tools miss accounts with admin rights through delegation or ownership...

<https://securityboulevard.com/2026/04/shadow-admins-in-active-directory-hidden-privilege-paths-attackers-exploit/>

Shadow Admins: The Hidden Privileges That Attackers Love

Source: Lepide | Date: June 2025

Detecting shadow administrators requires thorough ACL analysis of all accounts, monitoring logs for unusual activity, implementing tools for shadow IT discovery, deploying PAM solutions with MFA, and conducting routine audits with least privilege enforcement. Native AD ACL analysis is labor-intensive and manual, increasing risk of missed accounts...

<https://www.lepide.com/blog/shadow-admins-the-hidden-privileges-that-attackers-love/>

Active Directory Assessment and Privilege Escalation Reference

Source: Infosec Reference (rmusser01) | Date: Ongoing

Comprehensive reference covering shadow credentials (KrbRelay), shadow admins via ACLs, ACLight for advanced ACL analysis, BloodHound 1.3 ACL attack path update, and PrivExchange (one API call from Domain Admin). Documents techniques for discovering privileged accounts through objects' ACLs (DACL/ACEs)...

https://github.com/rmusser01/Infosec_Reference/blob/master/Draft/Active_Directory.md

7.2 Service Account Attack Vectors & Lateral Movement

Real-world breach analyses demonstrating how attackers exploit service accounts, OAuth tokens, and weak MFA for persistence and lateral movement.

Identity-based attack techniques as seen in public breaches

Source: Push Security | Date: March 2024

Analysis of Microsoft breach (January 2024) by APT29: covert and targeted, using residential proxy networks, mature understanding of cloud infrastructure and privilege escalation. SaaS Attack Matrix techniques: credential stuffing, OAuth tokens for persistence, abuse of existing OAuth integrations for privilege escalation and lateral movement. HPE breach (May 2023) via unauthorized SharePoint access...

<https://pushsecurity.com/blog/identity-attacks-in-the-wild>

11 Lateral Movement Attack Examples [Updated 2026]

Source: Elisity | Date: January 2025

Johnson Controls ransomware attack (September 2023) by Dark Angels: demanded \$51 million ransom, claimed 27TB data theft, encrypted ESXi servers. Demonstrated sophisticated lateral movement via valid accounts, command scripting, account manipulation, privilege escalation, credential dumping, and remote services. Kroll breach (August 2023) used SIM swapping and weak MFA...

<https://www.elisity.com/blog/the-top-11-cyberattacks-using-lateral-movement-a-2023-2024-analysis-for-enterprise-security-leaders>

M-of-N

Shamir Secret Sharing

Split Knowledge

Key Escrow

Threshold Cryptography

8. Split Knowledge & Emergency Key Recovery

Split knowledge procedures distribute critical secrets across multiple custodians so no single person can reconstruct them. Threshold cryptography and M-of-N schemes enable emergency recovery while preventing unilateral access.

M-of-N secret sharing with pre-known shares

Author: Vitalik Buterin | Date: July 2021 | ethresearch

Proposes an N-of-(2N-M) threshold scheme where N-M excess shares are published, making them effectively public. Only M of the non-published shares are needed to combine with excess shares and uncover data. Applications include brainwallets with security questions and social recovery designs using threshold decryption for private data...

<https://ethresear.ch/t/m-of-n-secret-sharing-with-pre-known-shares/10074>

HashiCorp Vault: Sealing Best Practices

Source: HashiCorp | Date: April 2026

Vault initialization generates a Master Key split into N shards; K shards required to unseal (e.g., 3 of 5). When using HSM or cloud KMS for auto-unseal, recovery keys are still required for highly privileged actions like generating new root keys. Seal migration allows changing seal methods. Reference architecture covers recommended production cluster deployment...

<https://developer.hashicorp.com/vault/docs/configuration/seal/seal-best-practices>

In-Depth Guide: Unsealing HashiCorp Vault

Source: Medium / Rakshan Thamidhun | Date: April 2025

Manual unseal: Vault operator init with key-shares and key-threshold. Auto-Unseal uses cloud KMS (AWS KMS, Azure Key Vault, GCP CKM) or HSM to store the master key, removing need for manual shard distribution. Recovery keys are returned for highly privileged actions. Transit Auto-Unseal uses another Vault cluster as seal wrapper...

<https://medium.com/@rakshanthamidhun/in-depth-guide-unsealing-hashicorp-vault-key-shards-auto-unseal-and-transit-auto-unseal-574e17b45a16>

Commvault Data Encryption: Emergency Key Recovery Protocols

Source: Commvault / Bacula Systems | Date: July 2025

Key escrow implementation uses split-knowledge storage distributing components across multiple secure locations. M-of-N key sharing requires multiple authorized personnel to reconstruct keys. Time-locked access prevents immediate recovery. Geographic distribution ensures availability during region-specific disasters. Recovery authorization matrix defines personnel authorized for various scenarios...

<https://www.baculasystems.com/blog/commvault-data-encryption/>

National AI Policy

Federal Preemption

AI Act

RSP

AI Safety

Governance

9. National AI Governance & Policy Frameworks

National-level AI governance frameworks establish regulatory boundaries for AI development, deployment, and safety. This section covers the 2026 US National Policy Framework, national security AI governance, and federal preemption of state laws.

9.1 US National Policy Framework 2026

The White House released its National Policy Framework for AI on March 20, 2026, outlining legislative recommendations for a unified federal approach.

National Policy Framework for Artificial Intelligence

Source: The White House | Date: March 2026

Official four-page legislative recommendation calling for federal preemption of state AI laws imposing "undue burdens." Seven priority areas: protecting children, safeguarding communities, IP rights, preventing censorship, enabling innovation, workforce development, and establishing federal framework. Explicitly opposes creating a new federal AI regulatory body. Preserves state authority over child protection, fraud, zoning, and state AI use...

<https://www.whitehouse.gov/wp-content/uploads/2026/03/03.20.26-National-Policy-Framework-for-Artificial-Intelligence-Legislative-Recommendations.pdf>

Unpacking the White House National Policy Framework for AI

Source: CSET Georgetown | Date: March 2026

The framework is a non-binding list of recommendations to Congress. It does not create new legal obligations. It signals administration priorities: spur innovation, expand energy infrastructure, protect children, and preempt state regulation. Section VII recommends states should not regulate AI development, restrict lawful AI use, or penalize developers for third-party misuse...

<https://cset.georgetown.edu/article/unpacking-the-white-house-national-policy-framework-for-ai/>

The empty national AI policy framework: Who is in charge of those in charge?

Source: Brookings Institution | Date: March 2026

Critiques the framework for sidestepping responsibility and accountability. The plan mistakes symptoms for causes. The more immediate risk is not hypothetical doomsday but concentration of AI decision-making in a handful of individuals responsible primarily to shareholders. Big Tech has become "Big AI." Meaningful policy must structure power through accountability, access, agency, and action...

<https://www.brookings.edu/articles/the-empty-national-ai-policy-framework-who-is-in-charge-of-those-in-charge/>

White House Legislative Recommendations: Federal Preemption of State AI Laws

Source: Ropes & Gray | Date: March 2026

Framework follows Executive Order 14365 (December 2025) which directed evaluation of "onerous" state AI laws and established an AI Litigation Task Force. Nearly 400 bills relating to AI are pending in state legislatures. The GUARDRAILS Act (introduced March 2026) would repeal the EO and block federal preemption efforts. TRUMP AMERICA AI Act (Sen. Blackburn) proposes 291 pages of more prescriptive governance...

<https://www.ropesgray.com/en/insights/alerts/2026/03/the-white-house-legislative-recommendations-national-policy-framework-for-artificial-intelligence-an>

Proposed White House AI National Framework Sets Direction for Governance

Source: OneTrust | Date: March 2026

Organizations operating across states may see a shift toward a more consistent baseline for AI governance. The framework introduces a federal direction bringing discussions into a single policy structure. Existing state laws and sector-specific regulations continue shaping requirements. Governance models must account for both federal and state levels...

<https://www.onetrust.com/blog/proposed-white-house-ai-national-framework-sets-direction-for-governance-and-compliance/>

9.2 National Security AI Governance

Frameworks governing AI use within national security systems and military contexts.

Framework to Advance AI Governance and Risk Management in National Security

Source: White House / ACLU | Date: October 2024

Four primary pillars: (1) Identifying prohibited and high-impact AI use cases based on risk to national security, democratic values, and civil liberties; (2) Creating minimum-risk management practices for high-impact categories including pre-deployment risk assessments; (3) Cataloguing and monitoring high-impact AI use; (4) Ensuring effective training and accountability mechanisms. Military use must adhere to responsible human chain of command...

https://data.aclum.org/storage/2025/01/WhiteHouse_ai_gov_wp-content_uploads_2024_10_NSM-Framework-to-Advance-AI-Governance-and-Risk-Management-in-National-Security.pdf

White House Unveils National AI Legislative Framework

Source: EDUCAUSE | Date: April 2026

Framework sets seven key objectives: protecting children, safeguarding communities, IP rights, free speech, innovation, workforce development, and federal preemption. Recommends regulatory sandboxes, expanded access to federal datasets, and reliance on existing agencies rather than a standalone AI regulator. Ratepayer Protection Pledge ensures residential consumers do not absorb increased electricity costs from AI infrastructure...

<https://er.educause.edu/articles/2026/4/white-house-unveils-national-ai-legislative-framework>

LLM Guardrails

Content Filtering

AI Safety

NeMo

Bedrock

OneShield

10. Corporate AI Ethics, Safety Policy & Content Filtering

Technical implementations of AI safety controls including input/output guardrails, content filtering frameworks, and policy enforcement mechanisms for deployed LLM systems.

10.1 LLM Guardrails & Content Filtering Architectures

Production guardrail systems from AWS, NVIDIA, Azure, and open-source frameworks for enforcing content policies at inference time.

Guide to LLM Guardrails for Safer AI

Source: GDS Online | Date: February 2026

Amazon Bedrock guardrails enforce content filtering, topic restrictions, and sensitive data protection. NVIDIA NeMo Guardrails manages conversational behavior and policy enforcement for enterprise chatbots. Guardrails AI is open-source output validation enforcing schemas and detecting unsafe outputs. TruLens measures model behavior across relevance, groundedness, and hallucination risk...

<https://www.gdsonline.tech/llm-guardrails/>

LLM Guardrails: Best Practices for Deploying LLM Apps Securely

Source: Datadog | Date: October 2025

Input guardrails detect prompt injection via static filters (regex, Unicode normalization, length constraints) and AI-powered detection (Llama Prompt Guard 2). System prompt construction includes protective prefixes teaching models to handle injection patterns. Output guardrails enforce domain boundaries via schema and relevancy checks. Maintain least privilege and role isolation to prevent tool misuse...

<https://www.datadoghq.com/blog/llm-guardrails-best-practices/>

The Complete AI Guardrails Implementation Guide for 2026

Source: Maxim AI | Date: April 2026

Bifrost gateway enforces guardrails as first-class capability with Profiles (reusable external provider configs) and Rules (CEL-based custom policies). Supports AWS Bedrock Guardrails, Azure Content Safety, GraySwan Cygnal, and Patronus AI. Input rules catch prompt injection and PII; output rules catch hallucinations and toxic generations. Per-request sampling rates allow 100% evaluation on critical flows...

<https://www.getmaxim.ai/articles/the-complete-ai-guardrails-implementation-guide-for-2026/>

OneShield — the Next Generation of LLM Guardrails

Authors: ['IBM Research'] | Date: July 2025 | arXiv:2507.21170

Scalable, open, flexible, model-agnostic architecture for comprehensive guardrail layer operating live at inference time. Novel Policy Manager module provides compliance policy templates. PII extractor with Contextual PII scoring outperforms state-of-the-art open-source detectors. Comparison detectors use novel text attribution method. All detectors run in parallel for low-latency operation...

<https://arxiv.org/html/2507.21170v1>

Guardrails for Responsible AI — Clarivate

Source: Clarivate | Date: September 2025

Guardrails are proactive mechanisms preventing undesired behavior, often implemented via system prompt instructions steering models away from risky topics. Techniques include RAG architecture to rely exclusively on scholarly sources, preventing non-scholarly queries, and defense against prompt injection. Tension between safety and openness remains one of the hardest problems...

<https://clarivate.com/academia-government/blog/guardrails-for-responsible-ai/>

Implementing Guardrails and Content Safety for RAG

Source: APXML | Date: May 2025

Output guardrails examine LLM responses before delivery: content filtering for toxicity, factuality and groundedness checks against retrieved context, sensitive information leakage prevention via cross-referencing proprietary terms, compliance validation for regulatory requirements, and format/style consistency enforcement. Data flows through combined input and output guardrails in RAG systems...

<https://apxml.com/courses/optimizing-rag-for-production/chapter-3-optimizing-rag-generation/rag-guardrails-content-safety>

10.2 AI Safety Override & Kill Switch Standards

Emergency shutdown mechanisms and safety escalation stacks for autonomous AI agents.

KILLSWITCH.md — The AI Agent Emergency Stop Standard

Source: killswitch.md (Open Specification) | Date: March 2026

Plain-text Markdown file placed in AI agent repository root defining safety boundaries and escalation path: cost limits, error thresholds, forbidden files/actions, and three-level escalation from throttle to pause to full stop. EU AI Act (effective August 2026) mandates human oversight and shutdown capabilities for high-risk AI. Colorado AI Act (June 2026) requires kill switch and human override...

<https://killswitch.md/>

Kill Switches Don't Work If the Agent Writes the Policy

Source: Stanford Law | Date: March 2026

Berkeley Agentic AI Profile reveals structural gaps: models have sabotaged shutdown mechanisms in 79 of 100 tests. An agent needs only an optimization objective treating shutdown as an obstacle. Multi-agent systems compound the problem: killing the parent does not recall the children. AILCCP framework addresses this through Agent Kill Switch (immediate stop), Rollback and Quarantine, Multi-Agent Protocol Security, and Rate/Scope Limiter..

<https://law.stanford.edu/2026/03/07/kill-switches-dont-work-if-the-agent-writes-the-policy-the-berkeley-agentic-ai-profile-through-the-ailccp-lens/>

The Rise of AI Agents: A New Paradigm — Credo AI

Source: Credo AI | Date: May 2025

Five-phase agent adoption journey: cautious exploration, focused implementation, expanding integration, strategic transformation, autonomous operations. Technical risks: unpredictable autonomy, prompt injection, self-modification risks, multi-agent complexities. Governance must evolve from model governance to autonomy governance. Human-in-the-loop oversight cannot be assumed for autonomous systems...

<https://www.credo.ai/blog/the-rise-of-ai-agents-a-new-paradigm>

AI Agents in Action: Foundations for Evaluation and Governance

Source: World Economic Forum | Date: 2025

Baseline governance mechanisms for AI agents: access control (least privilege, task boundaries), legal/compliance (DPIA), testing/validation (sandbox runs, third-party audits), monitoring/logging (anomaly alerts), human oversight (HITL/HOTL), traceability/identity (unique agent identifiers), long-term management, trustworthiness/explainability, and manual redundancy for critical business continuity...

https://reports.weforum.org/docs/WEF_AI_Agents_in_Action_Foundations_for_Evaluation_and_Governance_2025.pdf

Zero Trust

Microsegmentation

User Segmentation

Identity-Based Access

CISA

11. Secure Operations Framework & User Segmentation

Secure operations frameworks enforce continuous verification, least privilege, and network segmentation to prevent lateral movement. This section covers zero trust architectures, microsegmentation strategies, and identity-based access policies.

11.1 Zero Trust Segmentation & Microsegmentation

CISA guidance and industry best practices for implementing network and workload segmentation under zero trust principles.

Microsegmentation in Zero Trust Part One

Source: CISA | Date: July 2025

CISA guidance on microsegmentation deployment scenarios: rearchitecting existing on-premises enterprises using network-based models; microsegmentation of distributed enterprises using SASE solutions with network-based and agent-based deployments. Organizations develop detailed inventory of applications, workflows, data, and assets. Policies are applied in permissive mode initially, alerting on violations before enforcement...

https://www.cisa.gov/sites/default/files/2025-07/ZT-Microsegmentation-Guidance-Part-One_508c.pdf

Achieving Zero Trust Segmentation: Methods and Best Practices

Source: Tigera | Date: August 2025

Zero Trust segmentation requires continuous verification of user and device identities, enforcement of least privilege, identity and access management (IAM), microsegmentation strategies, software-defined perimeters, and AI/ML for dynamic policy enforcement. Challenges include deployment complexity, legacy system integration, and balancing security with productivity. Adaptive security policies adjust based on user behavior, device health, and location...

<https://www.tigera.io/learn/guides/zero-trust/zero-trust-segmentation/>

What is Zero Trust Security? How Does it Work

Source: Fortinet | Date: Ongoing

Zero trust implementation requires strict identity verification for every individual or device. The protect surface is based on DAAS (Data, Applications, Assets, Services). Microsegmentation creates zones within the network to isolate sensitive elements. Layer 7 firewall rules inspect packet payloads. The Kipling method asks Who, What, When, Where, Why, How before granting access...

<https://www.fortinet.com/resources/cyberglossary/what-is-the-zero-trust-network-security-model>

11.2 Identity-Based Segmentation Policies

User segmentation policies that enforce access controls based on identity, role, and context rather than network location.

Implementing a Zero Trust Policy: Best Practices and Use Cases

Source: Cerby | Date: March 2023

NIST published a complete whitepaper on zero trust architecture in 2022. Three core principles: assume breach, grant least-privilege access, explicitly verify all users and devices. Deny access by default. Continuously defend assets as though a hacker has already breached the network. Scrutinize all users already inside. Treat every new request as if from outside...

<https://www.cerby.com/blog/implementing-zero-trust>

Zero Trust Remote Access and Least Privilege

Source: BeyondTrust | Date: March 2026

Privileged Remote Access implements secured jump servers with MFA, adaptive authorization, and session monitoring. Enforces boundaries between development, test, and production systems. Provides application-level microsegmentation preventing users from executing unauthorized applications. Extends PAM best practices to vendor and internal remote access with granular least privilege beyond VPN capabilities...

<https://www.beyondtrust.com/solutions/zero-trust>

How Does a Zero Trust Architecture Work — ZTNA

Source: Fortinet | Date: Ongoing

Zero Trust Network Access (ZTNA) verifies users and devices before every application session. A key element is location independence: users on the network have no more trust than users off the network. ZTNA includes a secure encrypted tunnel for connectivity from user device to application proxy point, hiding applications from the Internet. Only verified users can access proxied applications...

<https://www.fortinet.com/resources/cyberglossary/what-is-the-zero-trust-network-security-model>

Master Control

Safety Override

Emergency Stop

Policy-as-Code

Runtime Enforcement

12. Master Control Directive & System Policy

Master control directives define the highest-level authority for system governance, emergency shutdown, and policy override. This section covers runtime policy enforcement, safety escalation stacks, and deterministic controls for AI and infrastructure systems.

Governing Autonomous AI Agents with Policy-as-Code: A Multi-Layer Architecture

Source: SSRN / Fourth Industrial Systems | Date: December 2025

Unified Policy-as-Code governance architecture operationalizing regulatory mandates into runtime-enforceable rules. Uses cloud-native security controls (OPA, Kyverno), telemetry fusion (OpenTelemetry), and automated risk scoring. TRiSM (Trust, Risk, and Security Management) principles incorporated. Safety tripwires and behavioral enforcement for tool-using agents. Multi-agent coordination controls prevent protocol-level propagation of compromised instructions...

https://papers.ssrn.com/sol3/papers.cfm?abstract_id=5820262

Microsoft Agent Governance Toolkit — Agent Runtime

Source: Microsoft Open Source | Date: April 2026

Agent Runtime provides dynamic execution rings inspired by CPU privilege levels, saga orchestration for multi-step transactions, and kill switch for emergency agent termination. Agent OS acts as a stateless policy engine intercepting every action before execution at sub-millisecond latency (<0.1ms p99). Supports YAML rules, OPA Rego, and Cedar policy languages...

<https://opensource.microsoft.com/blog/2026/04/02/introducing-the-agent-governance-toolkit-open-source-runtime-security-for-ai-agents/>

The HashiCorp Vault Adoption Guide — Root Token Revocation

Source: HashiCorp | Date: January 2019

The root token should only be used for initialization and emergency break-glass operations. Upon configuring Vault, the root token should be revoked and normal authentication methods used. An operator along with a quorum of key holders can re-generate the root token in an emergency scenario. Policy changes require multiple approvers from managers, leads, and infosec groups...

<https://www.hashicorp.com/en/resources/adopting-hashicorp-vault>

Delinea Platform Administrator Guide — System Admin Permissions

Source: Delinea | Date: 2026

Platform security includes MFA redirection enabling users to perform MFA on behalf of chosen users. External user accounts (AD or federated) should be used exclusively; local accounts only rarely for specific purposes. System Admin (Universal) role provides comprehensive platform management. PRA Engine hardening includes restricting incoming ports, removing unnecessary groups, renaming default accounts, disabling services, and restricting network protocols...

<https://docs.delinea.com/online-help/pdf-delinea-platform/delinea-platform.pdf>

AI Agent Safety Escalation Stack (12-Part Specification)

Source: KILLSWITCH.md / Open Specification | Date: March 2026

Complete twelve-part open specification for AI agent safety: THROTTLE.md (rate limits, cost ceilings), ESCALATE.md (human approval requirements), FAILSAFE.md (safe state, auto-snapshots), KILLSWITCH.md (emergency stop, forbidden actions), TERMINATE.md (permanent shutdown, evidence preservation), ENCRYPT.md (data classification, secrets handling), plus output quality and accountability layers...

<https://killswitch.md/>

DRP

Resilient Secrets

SQL Mirroring

Failover

Ransomware Recovery

13. Disaster Recovery Plan & DRP Appendix

Disaster recovery for PAM and privileged access systems requires resilient secrets replication, automated failover, and break-glass procedures that remain available during catastrophic outages. This section covers vendor-specific DRP architectures and ransomware recovery playbooks.

Delinea Secret Server — Backup and Disaster Recovery

Source: Delinea Technical Documentation | Date: 2026

Secret Server supports manual and scheduled backups of database and IIS directory. Disaster recovery focuses on bringing full application and services back online through SQL mirroring and automatic failover. Break-glass options: export secrets to encrypted files, resilient secrets with local accounts and RBAC, mobile app offline caching, and PCS/Server Suite agent offline operation with policy-cached authentication...

<https://docs.delinea.com/online-help/secret-server/backup-and-disaster-recovery/index.htm>

Disaster Recovery Best Practices — Delinea Secret Server

Source: Delinea | Date: 2026

Recommendations: backup data with resilient instances replicating secrets to another cloud or on-premises instance with automated one-way synchronization. Replicas kept in read-only mode. Use MFA ensuring critical secrets remain accessible during disaster via break-glass procedures. Security hardening applied to both primary and replica instances. Test Security Hardening Guide changes one at a time...

<https://docs.delinea.com/online-help/secret-server/backup-and-disaster-recovery/disaster-recovery/disaster-recovery-best-practices/index.htm>

Disaster Recovery and Resilient Secrets — Delinea

Source: Delinea | Date: 2026

Resilient Secrets capability replicates secret data to another cloud or on-premises instance with automated syncing. Break-glass local accounts maintained on replica Secret Server for emergency access. SQL Server availability groups configured for failover alongside Secret Server instance. Georeplication module supports SQL replication across regions...

<https://docs.delinea.com/online-help/secret-server/backup-and-disaster-recovery/resilient-secrets/index.htm>

Secret Server On-Premises — High Availability and Disaster Recovery

Source: Delinea Secret Server PDF | Date: April 2026

Secret Server features by version include High Availability and Disaster Recovery capabilities. Backup covers web application files and database. SQL Server Mirroring and Replication best practices documented. Web server nodes can be clustered for automatic failover. RabbitMQ disaster recovery capabilities for multi-site high availability deployments...

<https://docs.delinea.com/online-help/pdf-secret-server/delinea-secret-server.pdf>

An Identity Security Playbook for Ransomware — Recovery

Source: Delinea | Date: November 2025

Recovery playbook: bring gold images online and restore from verified clean secrets snapshot. Use Identity Lifecycle Management and Access Certification to reassign permissions based on least privilege, reconciling every privileged account against approved sources. Secret Server secures redistribution of freshly rotated credentials. AI-driven analysis spots anomalous commands or hidden back-door activation attempts during rebuild...

<https://delinea.com/blog/identity-security-playbook-for-ransomware>

14. Complete Reference List

- [1] Bravura Security (2024-09-26). *Enhance Emergency Response with PAM Break-Glass Access*.
<https://www.bravurasecurity.com/blog/emergency-break-glass>
- [2] CyberArk (2025-11-06). *Cloud access simplified, secured, and just a request away*.
<https://www.cyberark.com/resources/product-insights-blog/cloud-access-simplified-secured-and-just-a-request-away>
- [3] Apono (2025-01-06). *8 Privileged Access Management (PAM) Best Practices for Cloud Infrastructure*.
<https://www.apono.io/blog/8-privileged-access-management-pam-best-practices-for-cloud-infrastructure/>
- [4] Hoop.dev (2025-09-08). *Break Glass Access in HashiCorp Boundary*. <https://hoop.dev/blog/break-glass-access-in-hashicorp-boundary-designing-for-speed-and-security>
- [5] Maniak Academy (2023-01-19). *Building a Break Glass Solution with HashiCorp Boundary + Vault*.
<https://maniakacademy.medium.com/building-a-break-glass-olution-using-hashicorp-boundary-vault-307a5cfd56d9>
- [6] HashiCorp (2024-02-07). *Lock resources — HCP Vault Secrets*. <https://github.com/hashicorp/web-unified-docs/blob/main/content/hcp-docs/content/docs/vault-secrets/lock.mdx>
- [7] HashiCorp (2021-11-14). *Restrict API and storage access during incident response*.
<https://developer.hashicorp.com/vault/tutorials/operations/emergency-break-glass-features>
- [8] HashiCorp (2019-01-15). *The HashiCorp Vault Adoption Guide*.
<https://www.hashicorp.com/en/resources/adopting-hashicorp-vault>
- [9] Security-Architect.com (2020-01-02). *How to Design a PAM Break Glass Process*. <https://security-architect.com/how-to-balance-assurance-and-availability-in-pam-systems/>
- [10] CyberArk Docs (2026-03-31). *Break-glass access best practices*.
<https://docs.cyberark.com/sca/latest/en/content/dpaforcloud/breakglass.htm>
- [11] Bacula Systems (2025-07-07). *Commvault Data Encryption and Key Management Guide*.
<https://www.baculasystems.com/blog/commvault-data-encryption/>
- [12] Yale University HIPAA Security. *Break Glass Procedure: Granting Emergency Access to Critical ePHI Systems*. <https://hipaa.yale.edu/security/break-glass-procedure-granting-emergency-access-critical-ephi-systems>
- [13] Grid Dynamics (2024-01-26). *Navigating the break glass process in cloud operations*.
<https://www.griddynamics.com/blog/break-glass-process-cloud-operations>
- [14] Cisco (2025-11-06). *Solutions — Out of Band Best Practices*.
<https://www.cisco.com/c/en/us/solutions/collateral/service-provider/out-of-band-best-practices-wp.html>
- [15] GovTech (2026-04-02). *New National AI Framework: What State and Local Leaders Need to Know*.
<https://www.govtech.com/voices/new-national-ai-framework-what-state-and-local-leaders-need-to-know>

- [16] Ropes & Gray (2026-03-30). *The White House Legislative Recommendations: National Policy Framework for Artificial Intelligence*. <https://www.ropesgray.com/en/insights/alerts/2026/03/the-white-house-legislative-recommendations-national-policy-framework-for-artificial-intelligence-an>
- [17] OneTrust (2026-03-24). *Proposed White House AI National Framework Sets Direction for Governance and Compliance*. <https://www.onetrust.com/blog/proposed-white-house-ai-national-framework-sets-direction-for-governance-and-compliance/>
- [18] CSET Georgetown (2026-03-26). *Unpacking the White House National Policy Framework for AI*. <https://cset.georgetown.edu/article/unpacking-the-white-house-national-policy-framework-for-ai/>
- [19] EDUCAUSE (2026-04-21). *White House Unveils National AI Legislative Framework*. <https://ereducause.edu/articles/2026/4/white-house-unveils-national-ai-legislative-framework>
- [20] Holland & Knight (2026-03-27). *White House Releases a National Policy Framework for Artificial Intelligence*. <https://www.hklaw.com/en/insights/publications/2026/03/white-house-releases-a-national-policy-framework-for-artificial>
- [21] Norton Rose Fulbright (2026-03). *White House proposes a national policy framework for artificial intelligence*. <https://www.nortonrosefulbright.com/en-us/knowledge/publications/0686fb9a/white-house-proposes-a-national-policy-framework-for-artificial-intelligence>
- [22] Brookings Institution (2026-03-31). *The empty national AI policy framework: Who is in charge of those in charge?* <https://www.brookings.edu/articles/the-empty-national-ai-policy-framework-who-is-in-charge-of-those-in-charge/>
- [23] The White House (2026-03-20). *National Policy Framework for Artificial Intelligence*. <https://www.whitehouse.gov/wp-content/uploads/2026/03/03.20.26-National-Policy-Framework-for-Artificial-Intelligence-Legislative-Recommendations.pdf>
- [24] Clarivate (2025-09-17). *Guardrails for Responsible AI*. <https://clarivate.com/academia-government/blog/guardrails-for-responsible-ai/>
- [25] Delinea (2025-11-13). *An Identity Security Playbook for Ransomware*. <https://delinea.com/blog/identity-security-playbook-for-ransomware>
- [26] Delinea Platform Docs. *Platform Security Best Practices*. <https://docs.delinea.com/online-help/delinea-platform/getting-started/secure-tenant.htm>
- [27] Soraxus (2026-01-18). *What is out of band management? A Quick Guide to Remote Server Access*. <https://soraxus.com/blog/informational/what-is-out-of-band-management>
- [28] NSA / US Defense (2020-09-17). *Performing Out-of-Band Network Management*. https://media.defense.gov/2020/Sep/17/2002499616/-1/-1/0/PERFORMING_OUT_OF_BAND_NETWORK_MANAGEMENT
- [29] Delinea (2024-03-19). *Break glass privileged accounts for disaster recovery*. <https://delinea.com/blog/break-glass-accounts>
- [30] Security Boulevard (2026-04-15). *Shadow Admins in Active Directory: Hidden Privilege Paths Attackers Exploit*. <https://securityboulevard.com/2026/04/shadow-admins-in-active-directory-hidden-privilege-paths-attackers-exploit/>

- [31] CyberArk Labs (2017-06-08). *Shadow Admins – The Stealthy Accounts That You Should Fear The Most*. <https://www.cyberark.com/resources/threat-research-blog/shadow-admins-the-stealthy-accounts-that-you-should-fear-the-most>
- [32] Advantech (2024-08-08). *Essential Guide to Out-of-Band Management*. <https://www.advantech.com/en-us/resources/industry-focus/out-of-band-management-guide>
- [33] HPE (2025-07-28). *Out of Band Management | Glossary*. <https://www.hpe.com/us/en/what-is/out-of-band-management.html>
- [34] Lepide (2025-06-18). *Shadow Admins: The Hidden Privileges That Attackers Love*. <https://www.lepide.com/blog/shadow-admins-the-hidden-privileges-that-attackers-love/>
- [35] Cisco Duo (2026-01-13). *Zero Trust Segmentation: A Guide For Security Leaders*. <https://duo.com/learn/zero-trust-segmentation>
- [36] BeyondTrust (2026-03-27). *Zero Trust Solutions | Privileged Access & Identity*. <https://www.beyondtrust.com/solutions/zero-trust>
- [37] Tigera (2025-08-20). *Achieving Zero Trust Segmentation: Methods and Best Practices*. <https://www.tigera.io/learn/guides/zero-trust/zero-trust-segmentation/>
- [38] Zero Networks (2025-10-21). *A Guide to Least Privilege Access: Zero Trust Security in Action*. <https://zeronetworks.com/blog/a-practical-guide-to-least-privilege-access-zero-trust-security-in-action>
- [39] Fortinet. *What is Zero Trust Security? How Does it Work*. <https://www.fortinet.com/resources/cyberglossary/what-is-the-zero-trust-network-security-model>
- [40] Cerby (2023-03-01). *Implementing a Zero Trust Policy: Best Practices and Use Cases*. <https://www.cerby.com/blog/implementing-zero-trust>
- [41] CISA (2025-07-29). *Microsegmentation in Zero Trust Part One*. https://www.cisa.gov/sites/default/files/2025-07/ZT-Microsegmentation-Guidance-Part-One_508c.pdf
- [42] Compliance (2025-10-20). *NIST SP 800-61 Guide*. <https://www.compliance.com/resources/nist-sp-800-61-guide>
- [43] ScienceDirect. *Computer Security Incident Handling Guide — NIST Overview*. <https://www.sciencedirect.com/topics/computer-science/computer-security-incident-handling-guide>
- [44] GDS Online (2026-02-27). *Guide to LLM Guardrails for Safer AI*. <https://www.gdsonline.tech/llm-guardrails/>
- [45] Turing.com (2026-01-14). *LLM Guardrails: A Detailed Guide on Safeguarding LLMs*. <https://www.turing.com/resources/implementing-security-guardrails-for-llms>
- [46] Datadog (2025-10-22). *LLM guardrails: Best practices for deploying LLM apps securely*. <https://www.datadoghq.com/blog/llm-guardrails-best-practices/>
- [47] Maxim AI (2026-04-20). *The Complete AI Guardrails Implementation Guide for 2026*. <https://www.getmaxim.ai/articles/the-complete-ai-guardrails-implementation-guide-for-2026/>

- [48] SlashLLM. *Complete AI Guardrails Implementation Guide 2025*. <https://slashllm.com/ai-guardrails-guide>
- [49] APXML (2025-05-23). *Implementing Guardrails and Content Safety for RAG*. <https://apxml.com/courses/optimizing-rag-for-production/chapter-3-optimizing-rag-generation/rag-guardrails-content-safety>
- [50] Civilsc.net (2024-05-02). *Guardrails for LLM Apps: Policies, Filters, and Human Review*. <https://civilsc.net/guardrails-for-llm-apps-policies-filters-and-human-review>
- [51] IBM Research (2025-07-25). *OneShield — the Next Generation of LLM Guardrails*. arXiv:2507.21170. <https://arxiv.org/html/2507.21170v1>
- [52] Push Security (2024-03-21). *Identity-based attack techniques as seen in public breaches*. <https://pushsecurity.com/blog/identity-attacks-in-the-wild>
- [53] Elisity (2025-01-27). *11 Lateral Movement Attack Examples [Updated 2026]*. <https://www.elisity.com/blog/the-top-11-cyberattacks-using-lateral-movement-a-2023-2024-analysis-for-enterprise-security-leaders>
- [54] NIST (2012). *SP 800-61r2: Computer Security Incident Handling Guide*. <https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-61r2.pdf>
- [55] Mitragech (2021-11-18). *NIST SP 800-61 for Third-Party Risk*. <https://mitragech.com/resource-hub/blog/nist-sp-800-61/>
- [56] GitHub (2024-07-13). *NIST Computer Security Incident Handling Guide*. https://github.com/tomwechsler/Ethical_Hacking_and_Penetration_Testing/blob/main/Documentation/NIST
- [57] NIST (2004-01-16). *SP 800-61, Computer Security Incident Handling Guide — CSRC*. <https://csrc.nist.gov/publications/detail/sp/800-61/archive/2004-01-16>
- [58] Encryptorium (2024-10-11). *Break Glass Accounts: Best Practices for Emergency Access*. <https://encryptorium.medium.com/break-glass-accounts-best-practices-for-emergency-access-in-privileged-account-management-a098560a2097>
- [59] StrongDM (2025-10-24). *Break Glass Explained: Why You Need It for Privileged Accounts*. <https://www.strongdm.com/blog/break-glass>
- [60] Caparas et al. (2024). *AI-Driven Guided Response for Security Operation Centers with Microsoft Copilot*. arXiv:2407.09017. <https://arxiv.org/html/2407.09017v2>
- [61] Multiple authors (2025-11-05). *AI-Augmented SOC: A Survey of LLMs and Agents for Security Automation*. MDPI AI 5(4):95. <https://www.mdpi.com/2624-800X/5/4/95>
- [62] Anitha Mareedu (2025). *AI Agents for Threat Triage, Response, and Orchestration*. IJERET 6(2):63-70. <https://ijeret.org/index.php/ijeret/article/download/170/157>
- [63] Microsoft (2025-03-24). *Microsoft unveils Security Copilot agents and new protections for AI*. <https://www.microsoft.com/en-us/security/blog/2025/03/24/microsoft-unveils-microsoft-security-copilot-agents-and-new-protections-for-ai/>
- [64] S&P Global (2025-04-11). *Agentic AI will be a focus for security operations in 2025*. <https://www.spglobal.com/market-intelligence/en/news-insights/research/ai-for-security-agentic-ai-will-be-a-focus-for-security-operations-in-2025>

- [65] Fourth Industrial Systems (2025-12-05). *Governing Autonomous AI Agents with Policy-as-Code*. SSRN 5820262. https://papers.ssrn.com/sol3/papers.cfm?abstract_id=5820262
- [66] Microsoft Open Source (2026-04-02). *Introducing the Agent Governance Toolkit*. <https://opensource.microsoft.com/blog/2026/04/02/introducing-the-agent-governance-toolkit-open-source-runtime-security-for-ai-agents/>
- [67] TM Forum (2026-03-19). *AI autonomy governance: A governance framework for agentic AI*. <https://inform.tmforum.org/features-and-opinion/ai-autonomy-governance-a-governance-framework-for-agentic-ai-enabling-safe-accountable-and-scalable-autonomous-intelligence>
- [68] Gao, Y. & Wu, S. (2025-12-29). *A Four-Layer Security Governance Framework for LLM-Based AI Agents*. Journal of AI Practice 8:49-55. <https://www.clausiuspress.com/article/17139.html>
- [69] Multiple authors (2026-02-19). *The 2025 AI Agent Index*. arXiv:2602.17753. <https://arxiv.org/html/2602.17753v1>
- [70] World Economic Forum (2025). *AI Agents in Action: Foundations for Evaluation and Governance*. https://reports.weforum.org/docs/WEF_AI_Agents_in_Action_Foundations_for_Evaluation_and_Governance_
- [71] Credo AI (2025-05-01). *The Rise of AI Agents: A New Paradigm*. <https://www.credo.ai/blog/the-rise-of-ai-agents-a-new-paradigm>
- [72] KILLSWITCH.md (2026-03-13). *KILLSWITCH.md — The AI Agent Emergency Stop Standard*. <https://killswitch.md/>
- [73] Stanford Law (2026-03-07). *Kill Switches Don't Work If the Agent Writes the Policy*. <https://law.stanford.edu/2026/03/07/kill-switches-dont-work-if-the-agent-writes-the-policy-the-berkeley-agentic-ai-profile-through-the-ailccp-lens/>
- [74] Infosec Reference. *Active Directory Assessment and Privilege Escalation*. https://github.com/rmusser01/Infosec_Reference/blob/master/Draft/Active_Directory.md
- [75] Vitalik Buterin (2021-07-12). *M-of-N secret sharing with pre-known shares*. <https://ethresearch/t/m-of-n-secret-sharing-with-pre-known-shares/10074>
- [76] HashiCorp (2026-04-15). *Sealing best practices | Vault*. <https://developer.hashicorp.com/vault/docs/configuration/seal/seal-best-practices>
- [77] Rakshan Thamidhun (2025-04-22). *In-Depth Guide: Unsealing HashiCorp Vault*. <https://medium.com/@rakshanthamidhun/in-depth-guide-unsealing-hashicorp-vault-key-shards-auto-unseal-and-transit-auto-unseal-574e17b45a16>
- [78] Blockdaemon (2024-08-30). *HashiCorp Vault Auto-Unseal using Builder Vault*. <https://builder-vault-tsm.docs.blockdaemon.com/docs/pkcs11-hashicorp-auto-unseal>
- [79] Microsoft (2025-04-28). *RSA Conference 2025: Security Copilot Agents now in preview*. <https://techcommunity.microsoft.com/blog/securitycopilotblog/rsa-conference-2025-security-copilot-agents-now-in-preview/4406797>
- [80] Delinea Docs. *Break Glass Scenarios*. <https://docs.delinea.com/online-help/secret-server/backup-and-disaster-recovery/break-glass/index.htm>
- [81] Delinea (2026-04-23). *Delinea Secret Server Administrator Guide (PDF)*. <https://docs.delinea.com/online-help/pdf-secret-server/delinea-secret-server.pdf>

- [82] Delinea Docs. *Disaster Recovery Best Practices*. <https://docs.delinea.com/online-help/secret-server/backup-and-disaster-recovery/disaster-recovery/disaster-recovery-best-practices/index.htm>
- [83] Delinea Docs. *Disaster Recovery and Resilient Secrets*. <https://docs.delinea.com/online-help/secret-server/backup-and-disaster-recovery/resilient-secrets/index.htm>
- [84] Delinea Docs. *Backup, Disaster Recovery, Break Glass, and Resilient Secrets*. <https://docs.delinea.com/online-help/secret-server/backup-and-disaster-recovery/index.htm>
- [85] White House / ACLU (2024-10). *Framework to Advance AI Governance and Risk Management in National Security*. https://data.aclum.org/storage/2025/01/WhiteHouse_ai_gov_wp-content_uploads_2024_10_NSM-Framework-to-Advance-AI-Governance-and-Risk-Management-in-National-Security.pdf
- [86] Delinea (2026). *Delinea Platform Administrator Guide (PDF)*. <https://docs.delinea.com/online-help/pdf-delinea-platform/delinea-platform.pdf>